

Summary of the HIPAA Security Rule

HHS Office for Civil Rights - Public Domain

Administrative Safeguards

Administrative safeguards are administrative actions, policies, and procedures to manage the selection, development, implementation, and maintenance of security measures to protect electronic protected health information ePHI and to manage the conduct of the covered entities workforce in relation to the protection of that information.

Security Management Process - A covered entity must implement policies and procedures to prevent, detect, contain, and correct security violations.

Risk Analysis - A covered entity must conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity.

Technical Safeguards

Technical safeguards are the technology and the policy and procedures for its use that protect electronic protected health information and control access to it.

Access Control - Implement technical policies and procedures for electronic information systems that maintain ePHI to allow access only to those persons or software programs that have been granted access rights.

Audit Controls - Implement hardware, software, and procedural mechanisms that record and examine activity in information systems that contain or use ePHI.

Physical Safeguards

Physical safeguards are physical measures, policies, and procedures to protect a covered entity's electronic information systems and related buildings and equipment from natural and environmental hazards, and unauthorized intrusion.

Facility Access Controls - Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed.